

01

BOOK 01 / 08

시큐어코딩이란?

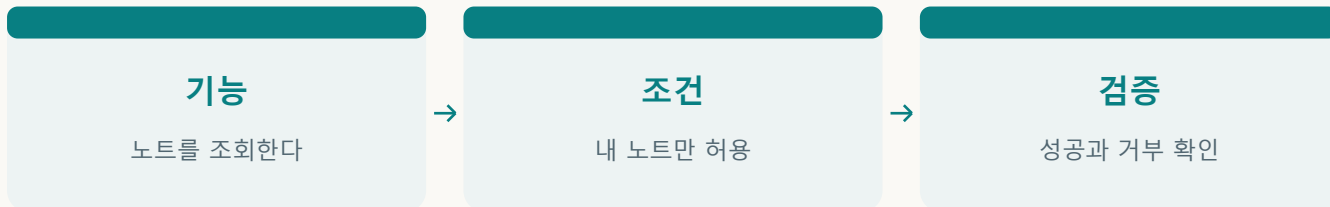
기능이 작동하면 안전한가?

개념 이해 / 사례 읽기 / 확인 문제 약 10분

비공개 학습 노트 서비스를 따라 배우는 보안의 기본

이 책을 읽는 방법

정상 동작과 보안 요구사항을 함께 확인합니다.



읽기 순서

학습 목표와 선수 지식	3
시작 상황: 조회는 잘 되는데 왜 문제일까?	3
개념 설명	3
동작 비교	3
개발·검수 시 확인사항	4
핵심 요약	4
확인 문제	5
정답과 해설	6
다음 학습과 출처	6

사례를 먼저 읽고, 개념과 코드의 차이를 확인한 뒤 문제를 풀어 보세요. 정답과 해설은 문제 다음 페이지에서 시작합니다.

공통 사례 / 비공개 학습 노트

민서(사용자 101)의 노트는 10번, 준호(202)의 노트는 20번입니다. 모든 노트는 비공개이며, 로그인한 소유자만 조회·수정할 수 있습니다. 제목은 1~80자의 일반 텍스트입니다.

비밀번호·세션 토큰은 로그에 남기지 않고, 권한을 확인할 수 없으면 본문을 보내지 않습니다. 이 가상 서비스의 예제는 학습용 축약본이며 실제 서비스의 계정·데이터·구현과 무관합니다.

학습 목표와 선수 지식

함수의 입력과 반환값을 안다고 가정합니다. 학습 후에는 기능 요구사항과 보안 요구사항의 차이를 설명하고, 정상 사용 사례 이외에 확인해야 할 상황을 제시할 수 있습니다.

시작 상황: 조회는 잘 되는데 왜 문제일까?

민서가 10번 노트를 열면 자신의 글이 표시됩니다. 개발자는 조회 기능이 잘 동작한다고 생각했습니다. 그런데 주소의 번호를 20으로 바꾸자 준호의 글도 표시됩니다.

두 요청 모두 서버 오류 없이 처리되었습니다. 하지만 두 번째 요청은 '자신의 노트만 조회할 수 있다'는 약속을 어겼습니다. 보안 문제는 프로그램이 멈추거나 오류 메시지를 보여줄 때만 발생하지 않습니다.

개념 설명

시큐어코딩은 소프트웨어를 만들 때 보안약점의 발생을 줄이도록 코드를 작성하고 확인하는 활동입니다. 특정 보안 함수를 붙이는 것만으로 끝나지 않습니다. 어떤 작업을 허용할지 설계하고, 코드에 그 조건을 반영하고, 조건을 어기는 요청이 차단되는지 확인해야 합니다.

기능 요구사항이 '노트를 조회한다'라면 보안 요구사항은 '요청자의 소유 노트만 조회한다'처럼 작성할 수 있습니다. 추상적인 '안전하게 조회한다'보다 입력과 기대 결과가 분명해 검사하기 쉽습니다.

기능 오류와 보안 문제는 서로 배타적인 분류가 아닙니다. 다른 사람의 노트가 표시되는 현상은 기능 요구사항 위반이면서 정보 노출 문제입니다. 반대로 글자 간격이 어긋나는 오류는 그 사실만으로 보안 문제라고 할 수 없습니다. 어떤 보호 조건을 위반하는지 살펴야 합니다.

동작 비교

다음은 실행용 코드가 아닌 의사코드입니다. '현재 사용자'는 인증 처리에서 확인한 사용자입니다.

PSEUDOCODE / 흐름 읽기

문제가 있는 흐름:

요청한 번호로 노트를 찾는다
노트 본문을 응답한다

개선한 흐름:

현재 사용자를 확인한다
현재 사용자가 소유한 노트 중 요청한 번호를 찾는다
찾지 못하면 본문을 보내지 않는다
찾으면 노트 본문을 응답한다

추가한 것은 단순한 오류 검사가 아니라 '누구의 노트를 가져올 수 있는가'라는 제한입니다. 번호가 숫자인지 확인하는 것만으로는 이 제한을 대신할 수 없습니다.

개발·검수 시 확인사항

정상 사례와 보호 조건을 어기는 사례를 한 쌍으로 적어 봅니다. '내 노트 조회 성공'과 '다른 사람의 노트 조회 거부'를 모두 확인해야 합니다. 거부만 확인하면 모든 요청을 차단하는 구현도 통과할 수 있습니다.

시큐어코딩 외에도 서버 설정, 구성요소 업데이트, 운영 권한 관리가 필요합니다. 이 과정은 코드와 가까운 판단을 배우며 서비스 전체의 안전성을 보장하지는 않습니다.

핵심 요약

- 정상 동작과 보안 요구사항 충족은 함께 확인해야 합니다.
- 보안 요구사항은 허용할 주체·대상·행동으로 구체화합니다.
- 수정 후에는 차단 결과뿐 아니라 정상 기능의 유지도 확인합니다.

확인 문제

1. 로그인한 사용자의 노트 목록이 표시되지만 다른 사용자의 노트도 섞여 있습니다. 오류 없이 조회되므로 보안 검사가 통과한 것일까요?

2. '노트 수정 기능'의 보안 요구사항을 한 문장으로 적어 보세요.

정답과 해설

1. 아닙니다. 조회 성공과 별개로 비공개 정보의 접근 제한을 위반했습니다.
2. 예: '인증된 사용자는 자신이 소유한 노트만 수정할 수 있어야 한다.' 사용자·대상·행동이 모두 들어 있는지가 핵심입니다.

다음 학습과 출처

다음 단원에서는 이 사례의 보호 대상과 피해를 보안 용어로 표현합니다. 시큐어코딩의 목적은 Python 시큐어코딩 가이드의 인쇄 4~5쪽을 참고했습니다. 노트 사례와 문제는 이 과정을 위해 작성했습니다.

나의 한 문장

이 강의에서 배운 내용을 동료에게 설명한다면 어떻게 말할까요?
